

HUNT THE TOKENS

UNCOVERING POST- AUTHENTICATION ATTACKS ACROSS YOUR ENVIRONMENT

Thomas Naunheim

Cyber Security Architect @glueckkanja AG

yellowhat.live





THOMAS NAUNHEIM

Cyber Security Architect @glueckkanja AG
Microsoft MVP (Identity & Access, Cloud Security)
Live in Koblenz/Lahnstein, Germany



cloud-architekt.net



Naunheim.cloud



thomasnaunheim



Thomas_Live

Thank you!

And BIG thanks to our sponsors!

baseVISION



FalconForce

Fellowwind

glueck■kanja



INSPARK



Microsoft



nedscaper

oneVinn



water

IT Security & Defense

wortell



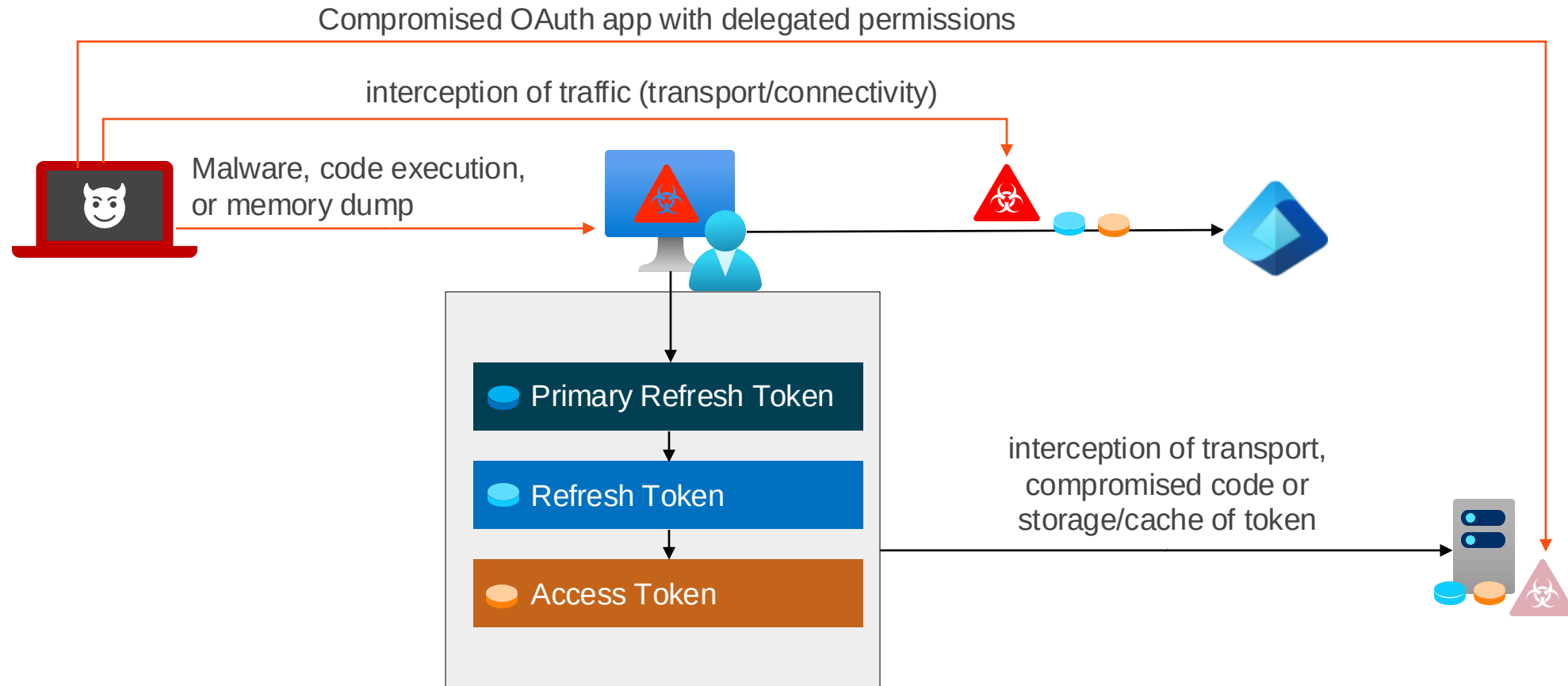
HUNT THE TOKENS | AGENDA

- Introduction to Token Theft and Post-Authentication Attacks
- Advanced insights of Microsoft Entra ID sign-in logs
- Correlation of sign-in events to XDR alert or anomalies
- Correlation of user sign-in, alert and cloud app activity logs
- Discover exposed token artifacts with Exposure Management

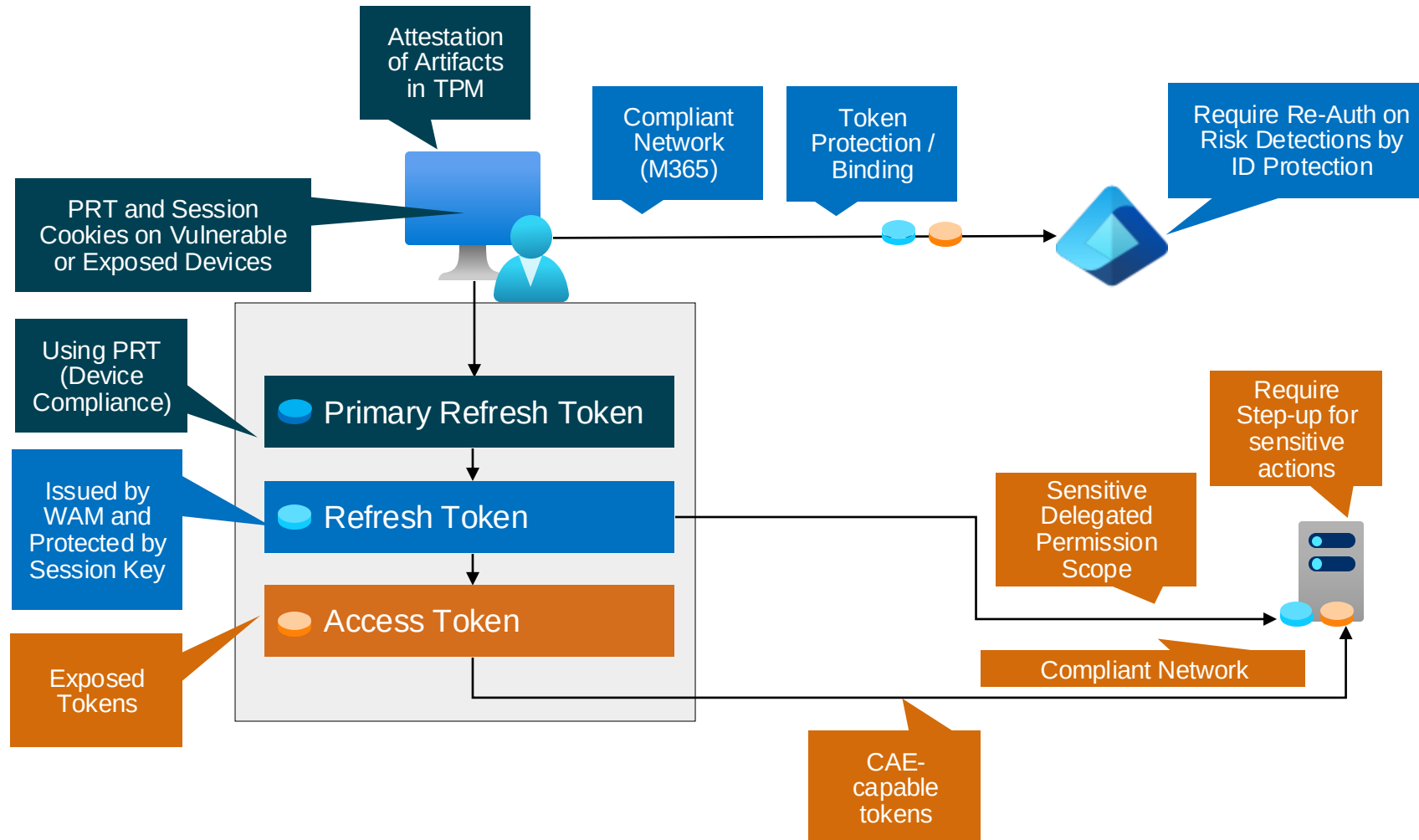


INTRODUCTION TO TOKEN THEFT AND POST-AUTHENTICATION ATTACKS

Token-related attack techniques



Mitigations and signals on token theft





ADVANCED INSIGHTS OF MICROSOFT ENTRA ID SIGN-IN LOGS

Types of Sign-in Identifiers

- **Correlation ID**

Groups sign-ins from the same sign-in session, generated by client (not IdP)

- **(Original) Request ID**

An identifier that corresponds to an issued token.

The request identifier of the first request in the authentication sequence

☐ TimeGenerated [UTC] ↑↓ ...	CorrelationId	OriginalRequestId	ResultType	AppDisplayName
☐ > 1/9/2025, 4:36:34.812 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	da64a1df-a440-4f9e-9384-8e1e74cc1600	50057	ZTNA Network Access Client
☐ > 1/9/2025, 4:38:50.378 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	99767c0a-a3e3-4bc9-911f-b435a02a2400	50057	ZTNA Network Access Client
☐ > 1/9/2025, 4:41:36.923 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	4dcb705e-e855-4737-943c-40a281832300	0	ZTNA Network Access Client
☐ > 1/9/2025, 4:41:39.250 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	535882bb-1efc-487f-9d3b-f3adf4d31c00	0	ZTNA Network Access Client
☐ > 1/9/2025, 4:44:17.870 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	b693d7da-a90b-4c51-97c7-c67932d02400	0	ZTNA Network Access Client
☐ > 1/9/2025, 5:20:40.974 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	7708cdc1-aeda-4669-a14c-66bb7aef4a00	0	ZTNA Network Access Client
☐ > 1/9/2025, 5:25:36.516 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	53ebf0ce-19f7-4238-99ab-5efd7c7f1a00	0	ZTNA Network Access Client
☐ > 1/9/2025, 5:27:46.532 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	bd6fe58a-12b5-4198-80be-0a4ef1ba2000	0	ZTNA Network Access Client
☐ > 1/9/2025, 5:33:53.056 PM	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	227ddc64-37eb-448b-a618-7d7987bc4200	0	ZTNA Network Access Client

Types of Sign-in Identifiers

- **Unique token identifier**

Used to correlate the sign-in with the token request (passed during the sign-in).

Track tokens issued by Microsoft Entra ID as they're redeemed at resource providers

☐	TimeGenerated [UTC] ↑↓	OriginalRequestId	UniqueTokenIdentifier ...	ResultType ...	AppDisplayName
☐	> 1/9/2025, 4:36:34.812 PM	da64a1df-a440-4f9e-9384-8e1e74cc1600	36Fk2kCknk-Thl4edMwWAA	50057	ZTNA Network Access Client
☐	> 1/9/2025, 4:38:50.378 PM	99767c0a-a3e3-4bcb-911f-b435a02a2400	Cnx2meOjy0uRH7Q1oCokAA	50057	ZTNA Network Access Client
☐	> 1/9/2025, 4:41:36.923 PM	4dcb705e-e855-4737-943c-40a281832300	XnDLTVXoN0eUPECigYMjAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 4:41:39.250 PM	535882bb-1efc-487f-9d3b-f3adf4d31c00	u4JYU_wef0idO_Ot9NMCAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 4:42:02.908 PM	10bea83a-c782-453e-ad0c-c77a94bb1700	Oqi-EILHPkWtDMd6lLsXAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 4:43:36.855 PM	da64a1df-a440-4f9e-9384-8e1e9cf41600	36Fk2kCknk-Thl4enPQWAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 4:44:17.870 PM	b693d7da-a90b-4c51-97c7-c67932d02400	2teTtgupUUyXx8Z5MtAkAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 5:20:40.974 PM	7708cdc1-aeda-4669-a14c-66bb7aef4a00	wc0ld9quaUahTGa7eu9KAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 5:25:36.516 PM	53ebf0ce-19f7-4238-99ab-5efd7c7f1a00	zvDrU_cZOEKZq179fH8aAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 5:27:46.532 PM	bd6fe58a-12b5-4198-80be-0a4ef1ba2000	iuVvzbUSmEGAvgpO8bogAA	0	ZTNA Network Access Client
☐	> 1/9/2025, 5:33:53.056 PM	227ddc64-37eb-448b-a618-7d7987bc4200	ZNx9lus3i0SmGH15h7xCAA	0	ZTNA Network Access Client

Types of Sign-in Identifiers

- **SessionId**

Identify and match the session (cookie) that was generated during the sign-in between the client and the IdP.

Timestamp ↑	CorrelationId	RequestId	SessionId	Application	ResourceDisplayName
> Jan 9, 2025 4:34:43 PM	aa9e2340-e1ef-486b-8b...	da64a1df-a440-4f9e-93...	ac38ab1b-89f0-415c-a3...	ZTNA Network Access C...	ZTNA Network Access Tr...
> Jan 9, 2025 4:36:43 PM	aa9e2340-e1ef-486b-8b...	99767c0a-a3e3-4bcb-91...	ac38ab1b-89f0-415c-a3...	ZTNA Network Access C...	ZTNA Network Access Tr...
> Jan 9, 2025 4:38:54 PM	aa9e2340-e1ef-486b-8b...	7708cdc1-aeda-4669-a1...	ac38ab1b-89f0-415c-a3...	ZTNA Network Access C...	ZTNA Network Access Tr...
> Jan 9, 2025 4:39:27 PM	aa9e2340-e1ef-486b-8b...	10bea83a-c782-453e-ad...	ac38ab1b-89f0-415c-a3...	ZTNA Network Access C...	ZTNA Network Access Tr...
> Jan 9, 2025 4:39:59 PM	aa9e2340-e1ef-486b-8b...	535882bb-1efc-487f-9d...	ac38ab1b-89f0-415c-a3...	ZTNA Network Access C...	ZTNA Network Access Tr...
> Jan 9, 2025 4:40:32 PM	aa9e2340-e1ef-486b-8b...	4dcb705e-e855-4737-9...	ac38ab1b-89f0-415c-a3...	ZTNA Network Access C...	ZTNA Network Access Tr...
> Jan 9, 2025 4:41:06 PM	aa9e2340-e1ef-486b-8b...	b693d7da-a90b-4c51-9...	ac38ab1b-89f0-415c-a3...	ZTNA Network Access C...	ZTNA Network Access Tr...

SessionId vs. CorrelationId

TimeGenerated ↑	SessionId	CorrelationId	Application	ResourceDisplayName
> Jan 9, 2025 4:06:25 PM	ac38ab1b-89f0-415c-a3...	b94145de-4a5f-4b52-97ce-076722d9d1e5	Microsoft Authentication ...	Windows Azure Active Directory
> Jan 9, 2025 4:06:25 PM	ac38ab1b-89f0-415c-a3...	b94145de-4a5f-4b52-97ce-076722d9d1e5	Windows Sign In	Azure Windows VM Sign-In
> Jan 9, 2025 4:06:43 PM	ac38ab1b-89f0-415c-a3...	6d3b97d2-82e6-45e9-9c12-08cd9fba31d5	Microsoft Application Co...	Microsoft Device Directory Service
> Jan 9, 2025 4:06:43 PM	ac38ab1b-89f0-415c-a3...	ee03da3d-af75-4f05-909f-653e011d5dba	Windows Shell	OfficeClientService
> Jan 9, 2025 4:06:44 PM	ac38ab1b-89f0-415c-a3...	08e1f413-fc3c-4c93-be49-e9e867d7fb79	Microsoft Application Co...	Microsoft Activity Feed Service
> Jan 9, 2025 4:06:47 PM	ac38ab1b-89f0-415c-a3...	2a374f9b-a6ed-492c-8119-71feb4709a75	Windows Shell	Microsoft Graph
> Jan 9, 2025 4:08:03 PM	ac38ab1b-89f0-415c-a3...	4f967753-39a1-4e25-8509-c611df4d89c5	OneDrive SyncEngine	Office 365 SharePoint Online
> Jan 9, 2025 4:34:43 PM	ac38ab1b-89f0-415c-a3...	aa9e2340-e1ef-486b-8b4e-1b7b8caabbea	ZTNA Network Access Cli...	ZTNA Network Access Traffic Profile
> Jan 9, 2025 4:34:50 PM	ac38ab1b-89f0-415c-a3...	cc20815b-379d-1900-9b24-2e73d9ab13a8	Microsoft Outlook	Office 365 Exchange Online
> Jan 9, 2025 4:38:46 PM	ac38ab1b-89f0-415c-a3...	961e37fb-991b-4540-98bd-9525b0edb39d	ZTNA Network Access Cli...	ZTNA Network Access Traffic Profile
> Jan 9, 2025 4:38:47 PM	ac38ab1b-89f0-415c-a3...	70ecebc1-0f10-490b-965e-ac59060091cf	ZTNA Network Access Cli...	ZTNA Network Access Traffic Profile
> Jan 9, 2025 4:38:53 PM	ac38ab1b-89f0-415c-a3...	c58b25f4-47db-1566-5a73-73d1b4ac30e1	Microsoft Outlook	Office 365 Exchange Online
> Jan 9, 2025 4:38:53 PM	ac38ab1b-89f0-415c-a3...	fec81d90-c132-46cd-9be4-7eb960ac0900	ZTNA Network Access Cli...	ZTNA Network Access Traffic Profile

Other token related properties

- **Incoming token types**

Token type that were presented to Microsoft Entra ID to authenticate the actor in the sign in (e.g., PrimaryRefreshToken, RefreshToken, SAML, None = Browser SSO / Direct Auth. via Creds)

- **Token Protection - Sign In Session**

Indicator if sign-in token (PRT/RT) was cryptographically bound to the device (or not)

- **AuthenticationProcessingDetails**

- Is CAE Token
- Oauth Scope Info

Graph, Diagnostic and XDR logs (2025-01)

Entra Portal – Sign-in events	Microsoft Graph Beta	Diagnostic Logs	AADSignInEventsBeta
Date	createdDateTime	CreatedDateTime	Timestamp
Correlation ID	correlationId	CorrelationId	CorrelationId (= ReportId)
Request ID	id (beta-Endpoint with empty OriginalRequestId)	id, OriginalRequestId	RequestId
Unique token identifier	uniqueTokenIdentifier	UniqueTokenIdentifier	N/A
Session ID	sessionId	N/A	SessionId
Token Protection Status	signInTokenProtectionStatus	N/A	N/A
Incoming token type	incomingTokenType	N/A	N/A
GlobalSecureAccessIpAddress	GlobalSecureAccessIpAddress	N/A	N/A
Through Global Secure Access	isThroughGlobalSecureAccess	N/A	N/A
Is CAE Token	Is CAE Token	Is CAE Token	N/A
Oauth Scope Info	Oauth Scope Info	Oauth Scope Info	N/A

Graph, Diagnostic and XDR logs (2025-02)

Entra Portal – Sign-in events	Microsoft Graph Beta	Diagnostic Logs	AADSignInEventsBeta
Date	createdDateTime	CreatedDateTime	Timestamp
Correlation ID	correlationId	CorrelationId	CorrelationId (= ReportId)
Request ID	id (beta-Endpoint with empty OriginalRequestId)	id, OriginalRequestId	RequestId
Unique token identifier	uniqueTokenIdentifier	UniqueTokenIdentifier	N/A
Session ID	sessionId	SessionId	SessionId
Token Protection Status	signInTokenProtectionStatus	signInTokenProtectionStatus	N/A
Incoming token type	incomingTokenType	incomingTokenType	N/A
GlobalSecureAccessIpAddress	GlobalSecureAccessIpAddress	N/A (Empty)	N/A
Through Global Secure Access	isThroughGlobalSecureAccess	isThroughGlobalSecureAccess	N/A
Is CAE Token	Is CAE Token	Is CAE Token	N/A
Oauth Scope Info	Oauth Scope Info	Oauth Scope Info	N/A

DEMO

Enrichment of sign-in data with mitigation capabilities for token theft and detection of unusual token issuance





CORRELATION OF SIGN-IN EVENTS TO XDR ALERT OR ANOMALIES

Risk detection details in Entra ID Protection

Risk Detection Details

 User's risk report  User's sign-ins  User's risky sign-ins  Linked risky sign-in

Detection type	Anomalous token ⓘ
Risk state	At risk
Risk level	Medium
Risk detail	-
Attack type(s)	Access using a valid account (Detected Offline), Steal Web Session Cookie/Token Theft
Source	Identity Protection
Detection timing	Offline
Activity	User
Detection time	8/14/2024, 5:36 PM
Detection last updated	8/14/2024, 5:36 PM
Token issuer type	Microsoft Entra ID
Sign-in time	8/14/2024, 9:16 AM
IP address	2607:f0d0:3602:69::4
Sign-in location	Montreal, Quebec, CA
Sign-in client	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Safari/537.36 Edg/127.0.0.0 OS/10.0.19045
Sign-in request id	9a227f17-eec8-407c-b2a5-28e8db17af00
Sign-in correlation id	92c40244-9b01-498e-88d5-e8bffc30d196

Risk Detections in relation to sign-in or token:

- Anomalous token (offline detection)
- Attempted access of PRT (by MDE)
- Unfamiliar sign-in properties
- Unfamiliar sign-in

Risk Detections by post-authentication activity:

- Mass Access to Sensitive Files
- Suspicious API traffic
- ...

Samples of behavior-based detections

- **Behaviors in Microsoft Defender XDR**

Mass download (OneDrive), Unusual addition of credentials to an OAuth app,...

- **User Entity Behavior Analytics (UEBA) in Microsoft Sentinel**

ML-based anomalies on activities but also sign-ins

Suspicious number of protected documents accessed

- **Alerts in Microsoft Defender for Cloud (e.g., Resource Manager)**

Suspicious management session using Azure Portal/PowerShell detected,...

- ...

DEMO

Enrichment of sign-in data with
related alerts from Microsoft
Defender XDR

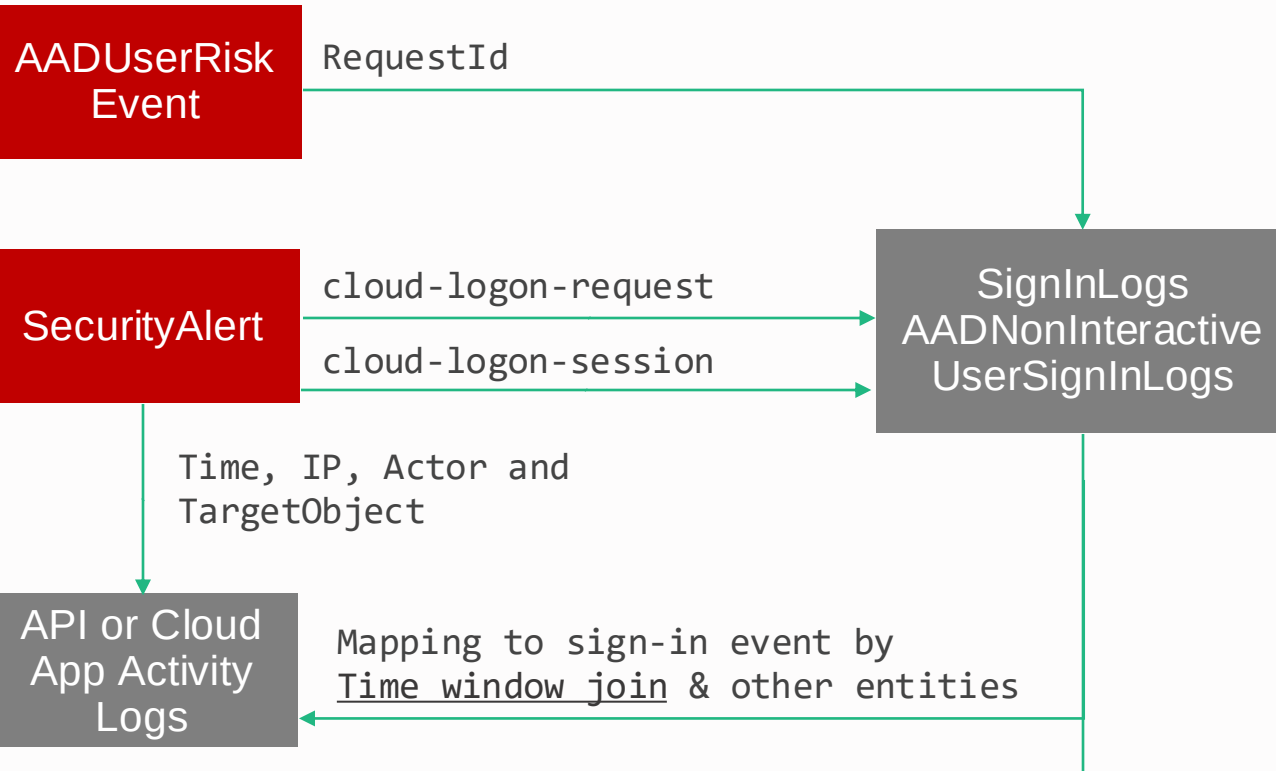




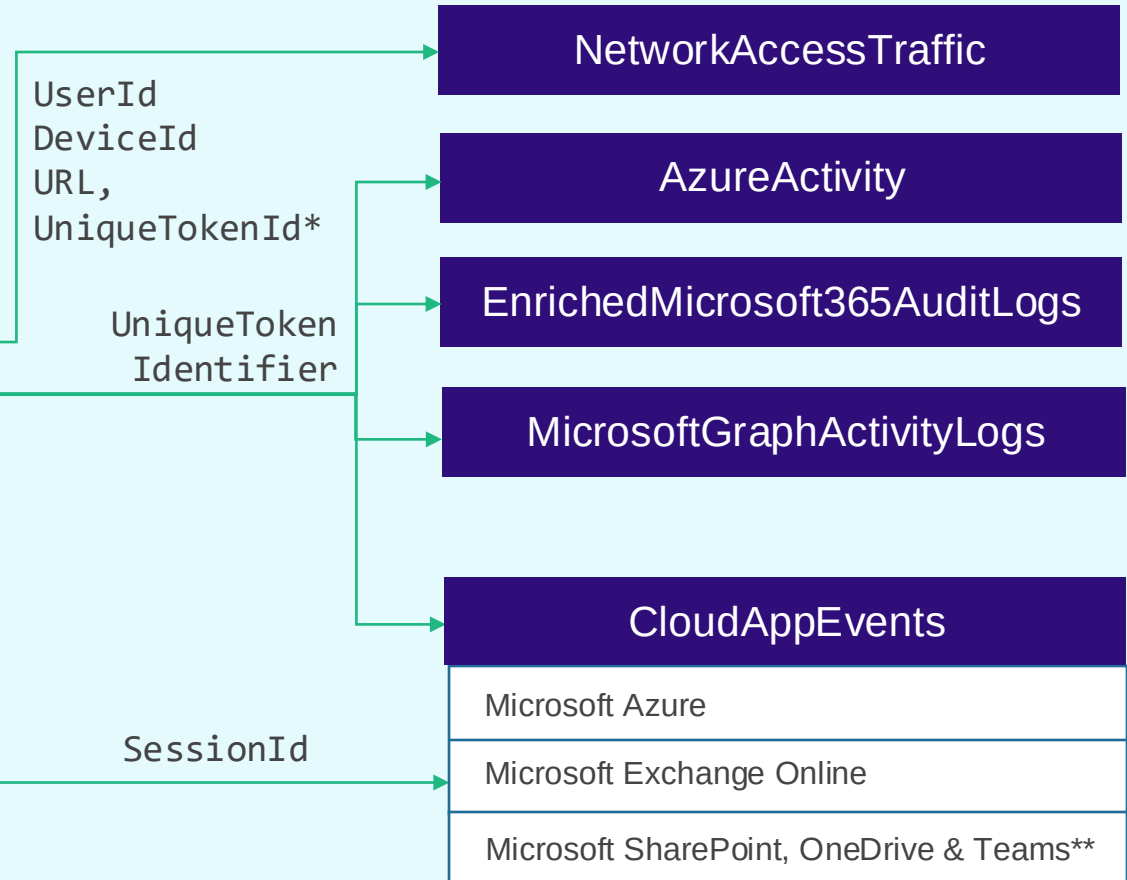
CORRELATION OF USER SIGN-IN, ALERT AND CLOUD APP ACTIVITY LOGS

Sign-in, alert and activity log mapping

Correlation XDR/SIEM Incident to suspicious sign-in



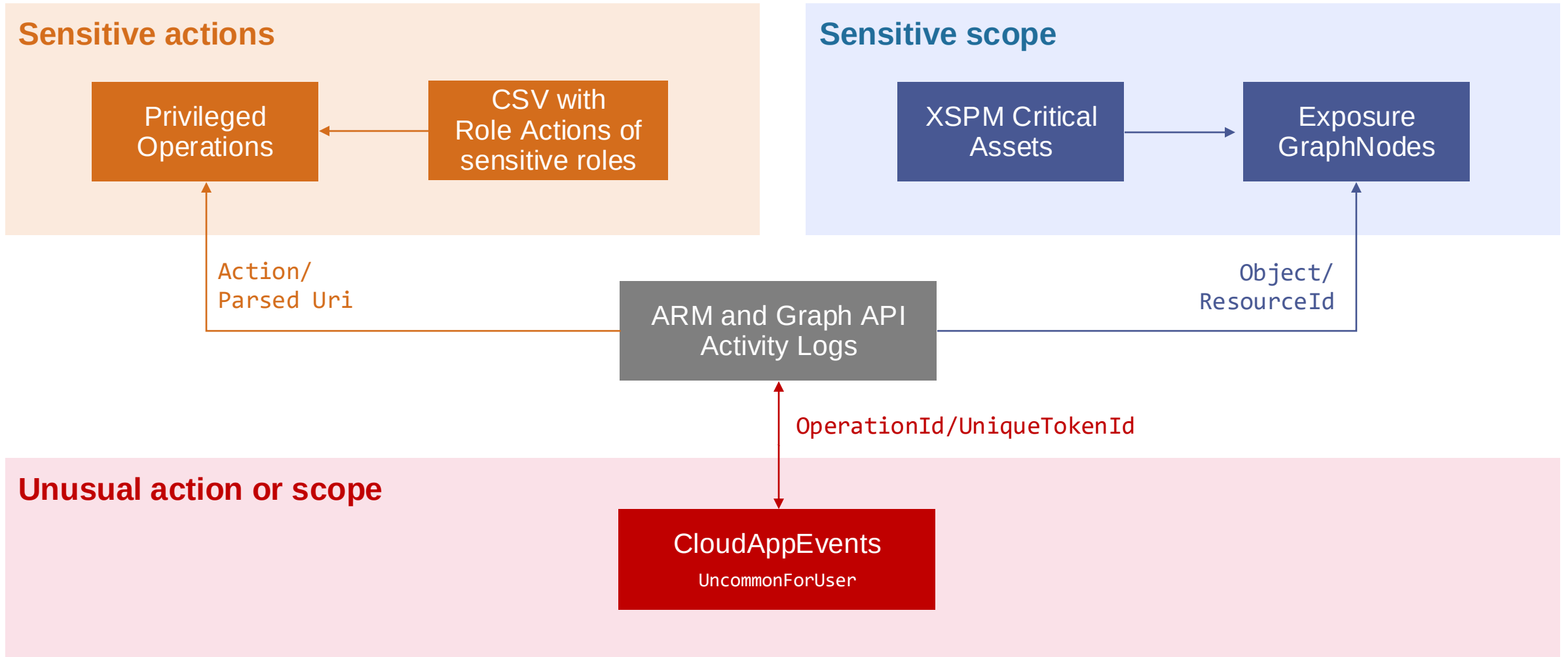
Correlation of token/session to activity



* limited to traffic for Entra ID token endpoint

** limited to specific ActionTypes of M365 workloads

Enrichment of sensitive actions or scope



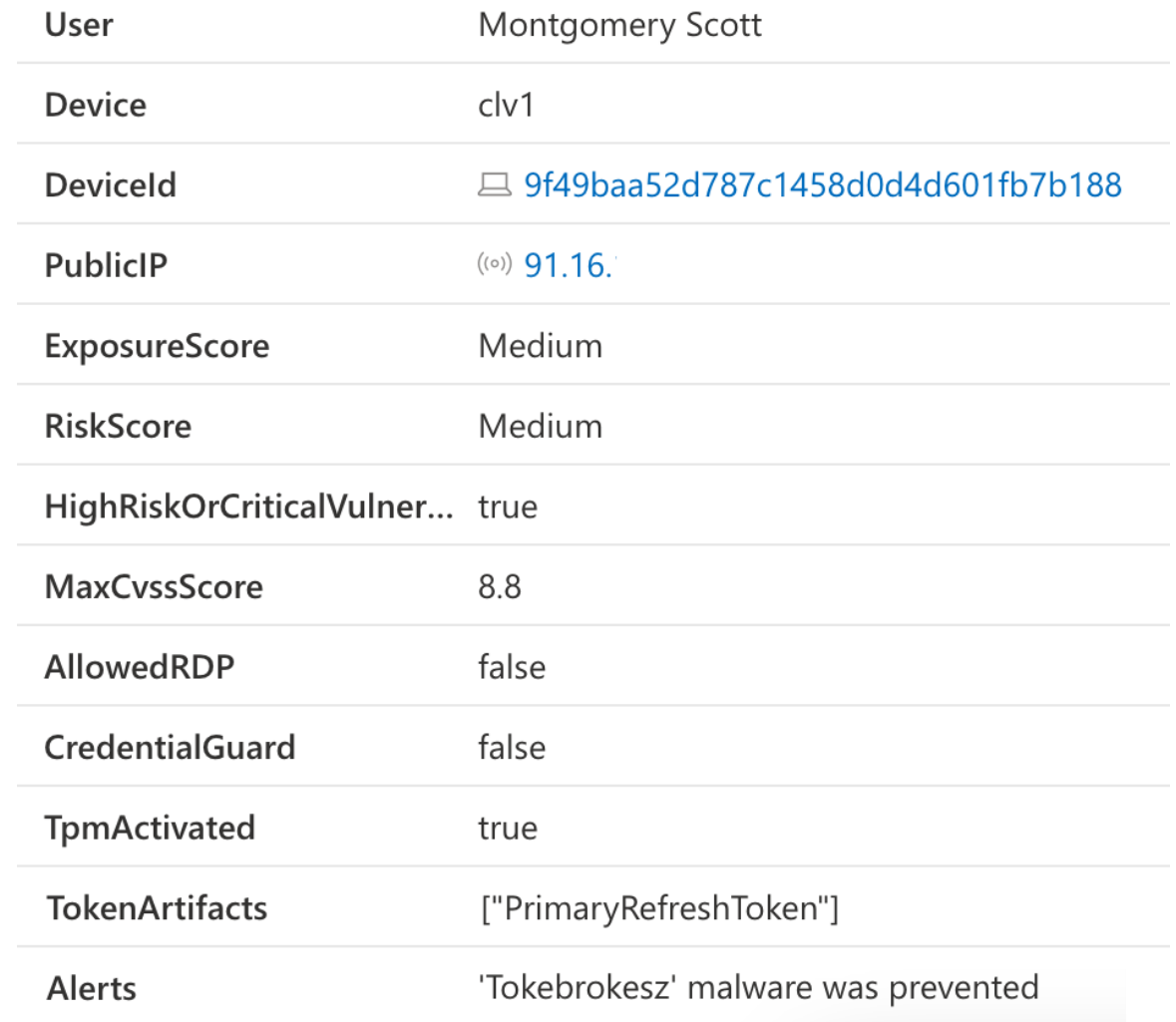
DEMO

Correlation of sign-in events
with compliant network and
cloud app access (post-
authentication events)





DISCOVER EXPOSED TOKEN ARTIFACTS WITH EXPOSURE MANAGEMENT

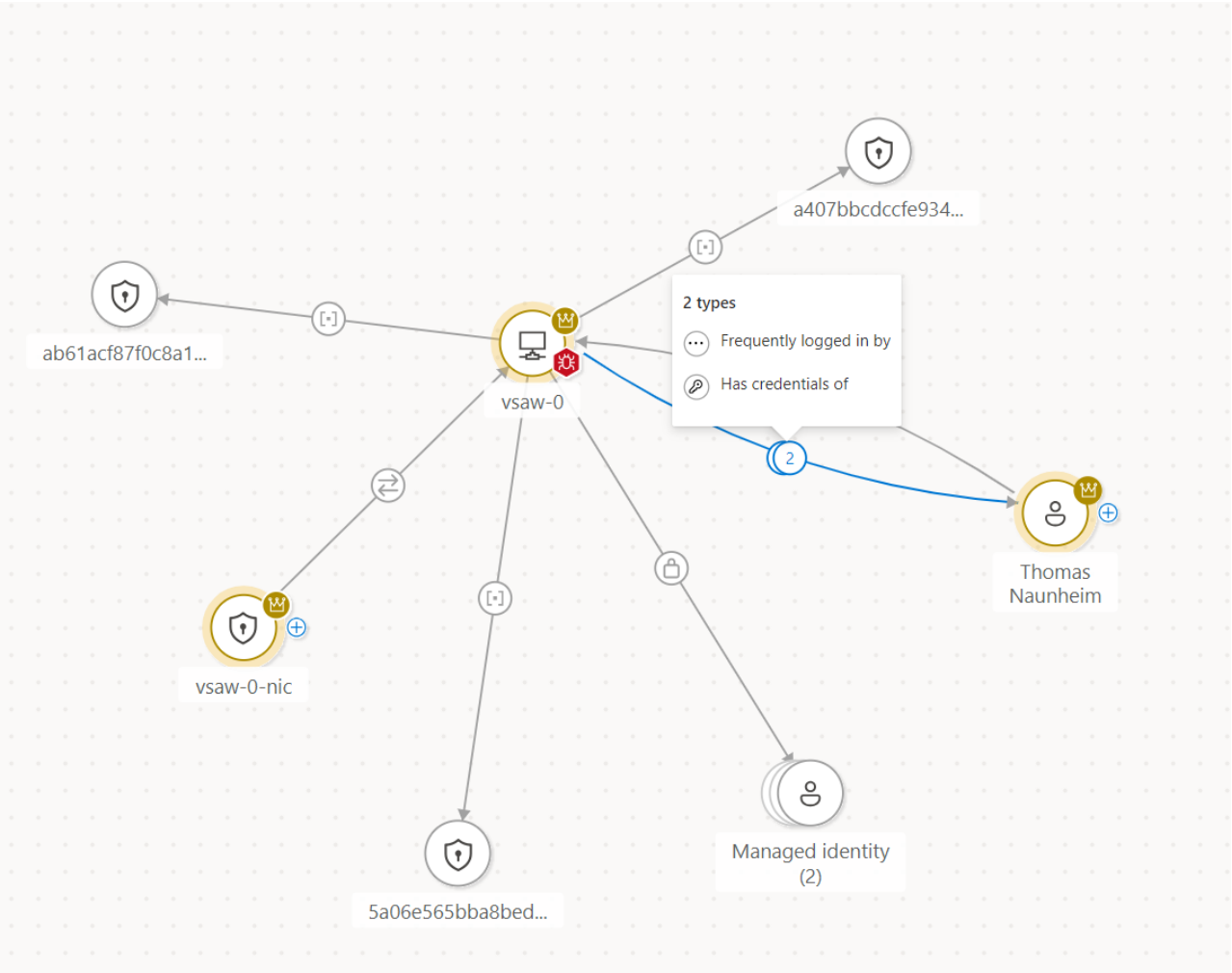


DISCOVER EXPOSED TOKEN ARTIFACTS WITH EXPOSURE MANAGEMENT

What about Authentication cookies?



Smart Analysis of Browser Artifacts



SourceNodeName	vsaw-0
SourceNodeLabel	microsoft.compute/virtualmachines
EdgeLabel	has credentials of
> browserCookies	{"type":"BrowserCookies","browserCookies":true}
> primaryRefreshToken	{"type":"PrimaryRefreshToken","primaryRefreshToken":true}
> cloudCliTool	{"type":"CloudCliTool","cloudCliTool":true}

THANK YOU!

Get hunting queries
from my demos



yellowhat.live

